Nonlinear Dyn
DOI 10.1007/s11071-015-2467-5

ORIGINAL PAPER

Robust extended chaotic maps-based three-factor authentication scheme preserving biometric template privacy

Qi Jiang · Fushan Wei · Shuai Fu · Jianfeng Ma · Guangsong Li · Abdulhameed Alelaiwi

Received: 30 March 2015 / Accepted: 21 October 2015
© Springer Science+Business Media Dordrecht 2015

Abstract Due to its high level of security, three-factor authentication combining password, smart card and biometrics has received much interest in the past decades. Recently, Islam proposed a dynamic identity-based three-factor authentication scheme using extended chaotic map which attempts to fulfill three-factor security and resist various known attacks, offering many advantages over existing works. However, in this paper we first show that the process of password verification in the login phase is invalid. Besides this defect, it is also vulnerable to user impersonation attack and off-line password guessing attack, under the condition that the smart card is lost or stolen. Furthermore, it fails to preserve biometric template privacy in the case that the password and the smart card are compromised. To remedy these flaws, we propose a robust three-factor authentication scheme, which not only resists various known attacks, but also provides more desired security features. We demonstrate that our scheme provides mutual authentication using the Burrows–Abadi–Needham logic. Our scheme provides high security strength as well as low computational cost.

Keywords Authentication · Key agreement · Chaotic map · Password · Smart card · Biometrics · Anonymity · Privacy

Q. Jiang (✉) · F. Wei · S. Fu · J. Ma
School of Cyber Engineering, Xidian University, Xi'an 710071, People's Republic of China
e-mail: jiangqixdu@gmail.com

G. Li
State Key Laboratory of Mathematical Engineering and Advanced Computing, Zhengzhou 450002, People's Republic of China

A. Alelaiwi
Department of Software Engineering, College of Computer and Information Sciences, King Saud University, P.O. Box 51178, Riyadh 11543, Kingdom of Saudi Arabia

1 Introduction

The advancement of information and communication technologies (ICT) has enabled a variety of online services, such as e-banking, e-shopping, e-government, and cloud data storage [1–3], to be acquired by using mobile devices over Internet. However, no inherent security infrastructure has been adopted by Internet, since its inception. Thus, remote authentication is indispensable to control the access to online services and ensure secure communication between a user and the application server [4–7].

Generally, an authentication scheme employs one of or the combination of three factors: something users know—password, something users have—smart card, and something users are—biometric characteristics [8,9]. Unfortunately, each factor has its own disadvantages [9,10]. For instance, passwords are vulnerable to off-line guessing attack, phishing, etc. Smart card can be lost or stolen, and the data stored in the

Published online: 30 October 2015

smart card can be extracted. Biometric data cannot be easily changed or revoked.

An effective approach to relieve these problems is to combine all these three factors together, which is known as three-factor authentication [9]. Moreover, there is an increasing demand for protecting user privacy from being disclosed and abused. Generally, there are two notions regarding user privacy, i.e., user anonymity and user untraceability. Specifically, user anonymity guarantees that the third party except the user and server could not determine the real identity of the user, and user untraceability ensures that the third party except the user and server could neither discern who the user is nor link different authentication sessions originated from the same user.

Apart from these, mobile devices are relatively limited in computing resource and power compared with desktop computers, and the scheme should be efficient in terms of computation and communication. In this direction, a number of three-factor authentication schemes preserving user privacy have been proposed in the literature [11–17]. However, most of them have been demonstrated either insecure against some basic attacks (e.g., stolen smart card attack [15]) or lack of some important features (e.g., preserving biometric template privacy [11–15]). The design of a secure and efficient three-factor authentication scheme preserving user privacy has proven not to be an easy task, as the designers are faced with the challenging task of reconciling usability, efficiency and security requirements.

1.1 Related works

Since chaotic map operations [18] are more efficient than traditional public key cryptographic operations, such as modular exponential operations and scalar multiplications over an elliptic curve, a number of chaotic maps-based authentication protocols have been proposed recently [19,20].

Password is the most common authentication factor for Internet applications (e.g., email services, social networks), and many password-based authentication schemes using chaotic maps have been developed. These schemes can be divided into two classes, i.e., two-party ones [21,22] and three-party ones [23–27]. However, this kind of authentication schemes has inherent vulnerabilities. For instance, passwords are susceptible to off-line guessing attacks, phishing, password capture Trojans, etc.

Two-factor authentication which combines password and smart card is an effective strategy to remedy those issues. Guo and Chang [28] proposed a two-factor authentication scheme based on chaotic map. However, Hao et al. [29] pointed out that in Guo and Chang's scheme, a third party can link different authentication sessions originated from the same user via a constant value, which violates user untraceability. To improve privacy and efficiency, they proposed another chaotic map-based authentication scheme. Although Hao et al.'s scheme enhances the privacy of Guo and Chang's scheme, Jiang et al. [30] identified that Hao et al.'s scheme is vulnerable to off-line password guessing attack under the condition that is the smart card is stolen. Yau and Phan [31,32] further identified that Guo and Chang's scheme [28] is susceptible to key-compromise impersonation and parallel session attacks, and has two weaknesses in the password change phase of the protocol. Li et al. [33] also proposed an extended chaotic map and dynamic ID-based user authentication protocol against denial of service (DoS) attack. Tan [34] proposed a novel chaotic map-based anonymous key agreement protocol over the interval $[-1, 1]$. However, the protocol needs additional operations on elliptic curves. Lee et al. [35] proposed an authentication and key agreement protocol for multi-server environments.

Unfortunately, in two-factor authentication, smart cards may be lost or stolen, and the data stored in the smart card can be extracted. To address such concern, three-factor authentication schemes have been proposed. Khan et al. [36] proposed a chaotic hash-based three-factor authentication scheme. Lee et al. [37] proposed chaotic maps-based three-factor key agreement with user anonymity, where hash functions are directly applied to biometrics. He et al. [38] showed that Lee et al.'s scheme suffers from privileged insider attack and DoS attack, and fails to provide anonymity. Then, they proposed an enhanced key agreement protocol. Later, Lee and Hsu [39] proposed a secure biometric-based remote user authentication with key agreement scheme using extended chaotic maps, which also provides user anonymity. However, this scheme has the same weakness as Lee et al.'s scheme [37].

Very recently, Islam [40] proposed a dynamic identity-based three-factor authentication scheme using extended chaotic map. The author claimed that their

scheme fulfills three-factor security and could resist various attacks, including smart card stolen attack. However, we observe that Islam's scheme is flawed.

Independently, a number of three-factor authentication schemes [11–17] using traditional cryptographic primitives other than chaotic ones have been proposed. However, these schemes are more or less flawed. In these earlier schemes [11–16], the captured biometric feature set is compared with the biometric template which is stored in the smart card to authenticate the user. One common drawback is that they fail to protect biometric template privacy. Since biometric features cannot be easily changed or revoked, it is critical to protect biometric template privacy.

To remedy it, Huang et al. [10] proposed a generic framework to upgrade two-factor authentication schemes to three-factor ones using the concept of fuzzy extractor [41]. Li et al. [17] proposed a concrete three-factor authentication scheme employing the same concept. Yu et al. [9] proposed a generic three-factor authentication framework employing fuzzy vault [42, 43], which is more efficient than Huang et al.'s scheme. He et al. [44] proposed a three-factor authentication scheme for universal serial bus (USB) devices. He and Wang [45] also proposed a three-factor authentication scheme for multi-server environment. These schemes [9,17,44,45] involve traditional public key cryptographic operations, which are less efficient than chaotic map operations.

1.2 Motivation and contributions

Although there are a number of three-factor schemes proposed in the literature, most of them are either inefficient to be implemented on smart cards (e.g., the schemes in [9,17,44,45]), or insecure against some serious threats like DoS attack due to noisy biometrics, off-line password guessing attack (e.g., the schemes in [36,39,40]). It still remains as a hard problem to develop a privacy-preserving three-factor protocol that is capable of resisting various known attacks while maintaining acceptable efficiency. The aim of this paper is to design a secure and efficient three-factor authentication scheme preserving user privacy using extended chaotic map.

In this paper, we use Islam's scheme [40] as a case study and demonstrate the subtleties and challenges in designing a practical chaotic map-based three-factor scheme preserving user privacy. We show that Islam's scheme suffers from the following drawbacks. Firstly, the process of password verification in the login phase is invalid. No matter the inputted identity and password are correct or not, the user can pass the password verification. Moreover, it is also vulnerable to user impersonation attack and off-line password guessing attack, in the case that the smart card is lost or stolen. Furthermore, it fails to preserve biometric template privacy in the case that the password and the smart card are compromised. In other words, the biometric template will be leaked in the case that the password and the smart card are compromised.

As our main contribution, we put forward a robust three-factor authentication scheme preserving biometric template privacy by employing the concept of fuzzy verifier [46] and fuzzy extractor [41]. Our new scheme makes up the missing security features necessary for real-life application environments while maintaining the desired features of the original scheme. Interestingly, the performance evaluation demonstrates that it attains these desired security features without incurring additional cost (in terms of communication and computation) as compared with Islam's scheme. We further prove the security of the proposed scheme using the Burrows–Abadi–Needham (BAN) logic.

1.3 Organization of the paper

The remainder of this paper is organized as follows. The next section introduces the preliminary of Chebyshev polynomial and fuzzy extractor briefly. Section 3 briefly reviews Islam et al.'s scheme. Section 4 elaborates on the flaws of their scheme. Section 5 presents the improved authentication scheme. In Sects. 6 and 7, the security and efficiency of the proposed scheme are discussed, respectively. Finally, the last section concludes the paper.

2 Preliminaries

2.1 Chebyshev chaotic maps

We briefly introduce the basics of Chebyshev chaotic map. Please refer to [47,48] for more details.

Definition 1 Chebyshev polynomial $T_n(x) : [-1, +1] \rightarrow [-1, +1]$ is defined as $T_n(x) = \cos(n \cdot \arccos(x))$,

where $x \in [-1, +1]$. The recurrence relation of Chebyshev polynomialis defined as $T_n(x) = (2xT_{n-1}(x) - T_{n-2}(x))$, where n is an integer, $n \geq 2$, $T_0(x) = 1$, $T_1(x) = x$.

To enhance the property of Chebyshev chaotic map, Zhang [48] proposed an improved Chebyshev polynomial defined on the interval $x \in (-\infty, +\infty)$ over $T_n(x) = (2xT_{n-1}(x) - T_{n-2}(x)) \mod p$, where p is a large prime number.

The improved Chebyshev polynomial satisfies the semi-group property, i.e., the equation $T_v(T_u(x)) = T_u(T_v(x))$ holds for $u, v \in N$ and $x \in (-\infty, +\infty)$, which is one of the best Chebyshev chaotic maps to construct cryptographic protocols.

Definition 2 (*Discrete logarithm (DL) problem*) Given two elements y and x, it is computationally infeasible to find an integer r such that $T_r(x) = y$.

Definition 3 (*Computational Diffie–Hellman (CDH) problem*) Given $x, T_r(x), T_s(x)$, it is computationally infeasible to compute $T_{rs}(x)$.

2.2 Fuzzy extractor

A fuzzy extractor extracts a nearly random string RS from the biometric input B in an error-tolerant way. If the inputted biometric B' changes but remains reasonably close to B, the extracted RS remains the same with the help of auxiliary string P. A fuzzy extractor is defined as two procedures (Gen, Rep).

(1) $Gen(B) = (RS, P)$.

Gen is a probabilistic generation procedure, which on biometric input B outputs an extracted string RS and an auxiliary string P.

(2) $Rep(B', P) = RS$, if B' is reasonably close to B.

Rep is a deterministic reproduction procedure, which allows to recover RS from the corresponding auxiliary string P and any vector B' reasonably close to B. For more details, please refer to [41].

3 Review of Islam's scheme

In this section, we review Islam's protocol based on chaotic maps [40], which is composed of six phases, i.e., setup, registration, login, authentication, password and biometric update, and lost smart card revocation. The notations used throughout the paper are listed as follows.

U	A user;
S	The remote server;
ID_U	U's identity;
PW_U	U's password;
DI_U	U's dynamic identity;
SC_U	U's smart card issued by S;
SI_U	The identifier of U's smart card;
B_U	U's biometric template;
RS_U	An extracted string extracted from U's biometric template;
P_U	An auxiliary string from U's biometric template;
p	A large prime number chosen by S with $\|p\| = 256$ bits;
SB_U	The status bit for U;
X_S	S's master key;
x	A real number chosen by S;
r_i	A random number chosen by the entity i;
SK	The session key established between U and S;
TI_i	The current timestamp of the entity i;
ΔTI_i	The time delay threshold for the entity i;
$H(\cdot)$	A secure one-way hash function;
$d(\cdot)$	A biometric matching function;
δ	A threshold value for biometric matching;
$T_n(x)$	A Chebyshev polynomial of degree n;
$\|\|$	The concatenation operation;
$\oplus$	The bitwise XOR operation.

3.1 Setup phase

Step 1 S chooses a large prime number p and X_S as the master secret key with the length of 256 bits.

Step 2 S selects a random number $x \in (-\infty, +\infty)$, computes $T_{X_S}(x)$, and a one-way hash function $H(\cdot) : \{0, 1\} \rightarrow Z_p^*$.

Step 3 S publishes $\langle p, H(\cdot), x \rangle$ as the system's public parameters.

3.2 Registration phase

U performs the following steps with S through a secure channel to be a legal user in this phase.

Step 1 U selects ID_U and sends it within a registration request to S.

Step 2 Upon receiving the registration request, S checks whether ID_U has been registered earlier. If it is, S rejects the request; otherwise, S initializes a new smart card SC_U for U. Then, S extracts SC_U's identifier SI_U, computes $A_U = H(ID_U||SI_U||X_S)$, stores $\langle A_U, p, H(\cdot), x, d(\cdot), \delta, T_{X_S}(x)\rangle$ into SC_U and issues the card to U. S maintains a table containing the tuples $\langle ID_U, SI_U, SB_U, R_U\rangle$. Initially, $R_U = \mathrm{null}$, SB_U is set to 1 if U is logged in; otherwise, it is set to 0. SI_U is for the purpose of revoking the lost smart card.

Step 3 After receiving SC_U, U selects the password PW_U and imprints the biometric B_U. Then, SC_U computes $C_U = H(ID_U||PW_U) \oplus B_U$, $D_U = A_U \oplus C_U$, $E_U = T_{A_U}(x)$. Next, SC_U replaces A_U by $\langle D_U, E_U\rangle$, and it holds $\langle D_U, E_U, p, H(\cdot), x, d(\cdot), \delta, T_{X_S}(x)\rangle$.

3.3 Login phase

In this phase, U initiates the authentication request and performs the following steps, as is shown in Fig. 1.

Step 1 U attaches his smart card SC_U to a card reader and inputs ID_U, PW_U and imprints B'_U.

Step 2 SC_U computes $B^*_U = C_U \oplus H(ID_U||\mathrm{PW}_U)$ and compares it with B'_U. If $\mathrm{d}(B'_U, B^*_U) > \delta$, SC_U rejects the request; otherwise, it computes $A^*_U = D_U \oplus H(ID_U||PW_U) \oplus B^*_U$ and $E^*_U = T_{A^*_U}(x)$. Then, if $E^*_U \neq E_U$, SC_U aborts the session; otherwise, it proceeds to the next step.

Step 3 SC_U generates the current timestamp TI_U, a random number $r_U \in_R Z^*_P$, and computes $R_U = T_{r_U}(x)$, $DI_U = ID_U \oplus H(T_{r_U}(T_{X_S}(x))||\mathrm{TI}_U)$, $L_U = H(DI_U||R_U||TI_U||A^*_U)$. Then, it sends the request message $\langle DI_U, R_U, TI_U, L_U\rangle$ to S.

3.4 Authentication phase

In this phase, U and S are mutually authenticated when U wants to request services. The following steps are performed, as is shown in Fig. 1.

Step 1 Upon receiving $\langle DI_U, R_U, TI_U, L_U\rangle$ at TI'_U, S checks whether $|TI'_U - TI_U| > \Delta TI_U$. If it is true, S rejects the request; otherwise, S extracts $ID_U = DI_U \oplus H(T_{X_s}(R_U)||TI_U)$ and checks the validity of ID_U. If it is invalid, S rejects the request; otherwise, S proceeds to the next step.

Step 2 S retrieves the tuple $\langle ID_U, SI_U, SB_U, R'_U\rangle$ and computes $A^*_U = H(ID_U||\mathrm{SI}_U||X_S)$, $L^*_U = H(DI_U||R_U||TI_U||A^*_U)$. If $L^*_U \neq L_U$, S rejects the request; otherwise, S further checks whether $R_U = R'_U$ holds. If it holds, S discards it as a replayed request; otherwise, S replaces $\langle ID_U, SI_U, SB_U, R'_U\rangle$ with $\langle ID_U, SI_U, \mathrm{SB}_U, R_U\rangle$.

Step 3 S obtains the timestamp TI_S and chooses a number $r_S \in_R Z^*_P$. Next, S computes $R_S = T_{r_S}(x)$, $\mathrm{SK} = H(ID_U||R_U||R_S||TI_U||TI_S||A_U||T_{r_S}(R_U))$ as the session key, and $L_S = H(ID_U||R_S||TI_S||A_U||SK)$, and then sends the response message $\langle R_S, TI_S, L_S\rangle$.

Step 4 After receiving the response message at TI'_S, U checks if $|TI'_S - TI_S| > \Delta\mathrm{TI}_S$. If it holds, U terminates the session; otherwise, U computes $SK = H(ID_U||R_U||R_S||TI_U||\mathrm{TI}_S||A_U||T_{r_S}(R_U))$ and $L^*_S = H(ID_U||R_S||TI_S||A_U||SK)$. If $L^*_S \neq L_S$, U aborts the session; otherwise, U has successfully authenticated S.

3.5 Password and biometric update phase

In this phase, U executes the following steps to update the password and biometrics.

Step 1 U inserts the smart card SC_U into a card reader, imprints B'_U and inputs $\langle ID_U, PW_U\rangle$.

Step 2 Then, SC_U computes $B^*_U = C_U \oplus H(ID_U||PW_U)$ and compares it with B'_U. If $\mathrm{d}(B'_U, B^*_U) > \delta$, SC_U rejects the request; otherwise, it computes $A^*_U = D_U \oplus H(ID_U||PW_U) \oplus B^*_U$ and $E^*_U = T_{A^*_U}(x)$. Then, if $E^*_U \neq E_U$, SC_U aborts the session; otherwise, it proceeds to the next step.

Step 3 U imprints B^n_U and inputs PW^n_U. Then, SC_U computes $D^n_U = A^*_U \oplus H(ID_U||PW^n_U) \oplus B^n_U$ and updates $\langle D_U, E_U, p, H(\cdot), x, d(\cdot), \delta, T_{X_S}(x)\rangle$ to $\langle D^n_U, E_U, p, H(\cdot), x, d(\cdot), \delta, T_{X_S}(x)\rangle$.

3.6 Lost smart card revocation phase

In this phase, U executes the following steps to revoke a lost smart card.

Fig. 1 Login and authentication phase of Islam's scheme

User U / Smartcard SC_U		Server S
Input $< ID_U, PW_U, B'_U >$		
$B_U^* = C_U \oplus H(ID_U \| PW_U)$		
If d(B'_U, B_U^*)>δ, reject		
Else, $A_U^* = D_U \oplus H(ID_U \| PW_U) \oplus B_U^*$		
$E_U^* = T_{A_U^*}(x)$		
If $E_U^* \neq E_U$, abort		
Else, generate $TI_U, r_U \in_R Z_P^*$		
$R_U = T_{r_U}(x)$		
$DI_U = ID_U \oplus H(T_{r_U}(T_{X_S}(x)) \| TI_U)$		
$L_U = H(DI_U \| R_U \| TI_U \| A_U^*)$		
	$< DI_U, R_U, TI_U, L_U >$ →	
		If $\|TI'_U - TI_U\| > \Delta TI_U$, reject
		Else, $ID_U = DI_U \oplus H(T_{X_s}(R_U) \| TI_U)$
		If ID_U is invalid, abort
		Else, retrieve $<ID_U, SI_U, SB_U, R'_U>$
		$A_U^* = H(ID_U \| SI_U \| X_S)$
		$L_U^* = H(DI_U \| R_U \| TI_U \| A_U^*)$
		If $L_U^* \neq L_U$, abort
		Else, if $R_U = R'_U$, reject
		Else, update $<ID_U, SI_U, SB_U, R'_U>$
		Generate $TI_S, r_S \in_R Z_P^*$
		$R_S = T_{r_S}(x)$
		$DI_U = ID_U \oplus H(T_{r_U}(T_{X_s}(x)) \| TI_U)$
		$SK = H(ID_U \| R_U \| R_S \| TI_U \| TI_S \| A_U \| T_{r_S}(R_U))$
		$L_S = H(ID_U \| R_S \| TI_S \| A_U \| SK)$
	← $< R_S, TI_S, L_S >$	
If $\|TI'_S - TI_S\| > \Delta TI_S$, abort		
Else, $SK = H(ID_U \| R_U \| R_S \| TI_U \| TI_S \| A_U \| T_{r_S}(R_U))$		
$L_S^* = H(ID_U \| R_S \| TI_S \| A_U \| SK)$		
If $L_S^* \neq L_S$, abort		
Else, the authentication session succeeds		

Step 1 U sends ID_U within the smart card revocation request to S.

Step 2 S checks the validity of U and ID_U. If both are valid, S gets a new smart card SC_U^n, extracts the identity SI_U^n, calculates $A_U^n = H(ID_U||SI_U^n||X_S)$, stores $\langle A_U^n, p, H(\cdot), x, d(\cdot), \delta, T_{X_S}(x)\rangle$ into SC_U^n and issues the card to U. S updates the tuple $\langle ID_U, SI_U, \mathrm{SB}_U, R_U\rangle$ to $\langle ID_U, SI_U^n, SB_U, R_U\rangle$.

Step 3 After receiving SC_U^n, U selects the new password PW_U^n and imprints the new biometric B_U^n. Then, SC_U^n computes $C_U^n = H(ID_U||PW_U^n) \oplus B_U^n$, $D_U^n = A_U^n \oplus C_U^n$, $E_U^n = T_{A_U^n}(x)$. Next, SC_U^n replaces A_U^n by

$\langle D_U^n, E_U^n \rangle$, and it holds $\langle D_U^n, E_U^n, p, H(\cdot), x, d(\cdot), \delta, T_{X_S}(x) \rangle$.

4 Weaknesses of Islam's scheme

To analyze the security of three-factor authentication schemes, we suppose that the adversary may intercept, insert, delete or modify any message transmitted through the channel between the user and the server. Moreover, the information stored in the smart card may be exposed when the card is lost or stolen, since the secret information in it can be extracted by side channel attacks [49,50].

Truly three-factor authentication should still be secure even if any two of three factors are compromised. More specifically, three-factor security should still be secure in three different cases: the password and the biometric template are compromised, the password and the smart card are compromised, and the biometric template and the smart card are compromised.

Although Islam's scheme is claimed to be secure against various attacks, we observe that the scheme fails to fulfill three-factor security. Concretely, it has the following drawbacks.

(1) The process of password verification in the login phase is invalid. That is, no matter the inputted identity and password are correct or not, the user can pass the password verification.
(2) An adversary can successfully generate a valid login message and impersonate as the card owner without the password and biometrics, if the smart card is lost or stolen.
(3) An adversary can launch off-line password guessing attack if the smart card is stolen.
(4) The biometric template will be leaked in the case that the password and the smart card are compromised.

Note that Islam's scheme has inconsistency in the design. In the registration phase, the parameters stored in the card are $\langle D_U, E_U, p, H(\cdot), x, d(\cdot), \delta, T_{X_S}(x) \rangle$ without C_U. However, in the login phase, the card uses C_U to compute $B_U^* = C_U \oplus H(ID_U||PW_U)$. Moreover, C_U is essential in the login phase, if it is absent, it is impossible to perform the login phase. As a result, we assume that C_U is stored in the card in the registration phase.

4.1 Invalid password verification

In the login phase of Islam's scheme, the smart card first verifies the genuineness of the user by comparing the newly captured biometric feature set with the biometric template stored in it. Then, it continues to verify the validity of the identity and password provided to authenticate the user. However, we observe that the process of password verification is of no avail. No matter the inputted identity and password are correct or not, the verification will always be true. That is, a user can always pass the verification procedure. The details are presented as follows.

In the login phase, SC_U computes $A_U^* = D_U \oplus H(ID_U||PW_U) \oplus B_U^*$ and $E_U^* = T_{A_U^*}(x)$. Then, it verifies the validity of the inputted ID_U, PW_U through checking whether $E_U^* \neq E_U$ holds. However, we identify that $E_U^* \neq E_U$ holds even when the inputted ID_U and PW_U are incorrect. To be clear, we denote the identity and password inputted in the login phase as ID_U^* and PW_U^*, respectively. Now, we have the equations $C_U = H(ID_U||\mathrm{PW}_U) \oplus B_U, D_U = A_U \oplus C_U, E_U = T_{A_U}(x)$, which are computed in the registration phase and stored in the smart card. Then, SC_U computes $B_U^* = C_U \oplus H(ID_U^*||PW_U^*)$, $A_U^* = D_U \oplus H(ID_U^*||\mathrm{PW}_U^*) \oplus B_U^*$, $E_U^* = T_{A_U^*}(x)$. We can get that $A_U^* = A_U$ always holds, no matter the inputted identity and password are correct or not. The derivation is given as follows.

$$\begin{aligned} A_U^* &= D_U \oplus H\left(ID_U^*||PW_U^*\right) \oplus B_U^* \\ &= (A_U \oplus C_U) \oplus H\left(ID_U^*||\mathrm{PW}_U^*\right) \\ &\quad \oplus \left(C_U \oplus H\left(ID_U^*||PW_U^*\right)\right) \\ &= A_U \oplus \left(C_U \oplus H\left(ID_U^*||\mathrm{PW}_U^*\right)\right) \\ &\quad \oplus \left(C_U \oplus H\left(\mathrm{ID}_U^*||PW_U^*\right)\right) \\ &= A_U \end{aligned}$$

The above discussion indicates that the verification of identity and password is of no avail or useless in the login phase.

4.2 Stolen smart card attack

In three-factor authentication, all three security factors are needed to generate a valid login message. However, an adversary can generate a valid login message with only the smart card of a user. Suppose that an adversary A has stolen U's card and extracted the stored information $\langle C_U, D_U, E_U, p, H(\cdot), x, d(\cdot), \delta, T_{X_S}(x) \rangle$. Then,

A can derive $A_U = D_U \oplus C_U$ with the parameters stored in the card and construct a legal request message, since the only secret information in the request message is the value A_U. The details are given as follows.

(1) A derives $A_U = D_U \oplus C_U$, generates the current timestamp TI_U, a random number $r_U \in_R Z_P^*$, and computes $R_U = T_{r_U}(x), DI_U = ID_U \oplus H(T_{r_U}(T_{X_S}(x))||TI_U)\, L_U = H(DI_U||R_U||\mathrm{TI}_U||A_U)$. Then, it sends the request message $\langle \mathrm{DI}_U, R_U, TI_U, L_U \rangle$ to S.
(2) Upon receiving the request message, S performs the specified verifications. It is obvious that $L_U^* = L_U$ holds. That is, the adversary has passed the verification performed by S.

The above discussion concludes that an adversary can generate a valid login message without the user's password and biometrics. This proves that this scheme fails to fulfill three-factor security.

4.3 Off-line password guessing attack with the stolen smart card

Since passwords are chosen by users for easy remembrance, they are potentially vulnerable to password guessing attack, including detectable online password guessing attack, undetectable online password guessing attack and off-line password guessing attack [51, 52]. It is essential to resist off-line password guessing attack even if the smart card and biometric template are compromised in three-factor authentication schemes.

In [40], Islam claimed that the scheme is secure against the stolen smart card attack based on the assumption that the user identity and biometrics are unknown. As is indicated by Wang et al. [6], an adversary can somehow know the victim's identity after obtaining the victim's card, since a user's identity is of weak cryptographic strength. So, it is more practical to regard user identity as a known value.

We observe that Islam's scheme suffers from off-line password guessing attack. An adversary A can mount this attack with the request messages and the stolen smart card of a specific user. Two assumptions are made as follows.

First, A eavesdrops the messages transmitted between the user and server and stores the messages $\langle DI_U, R_U, TI_U, L_U \rangle$, where $L_U = H(DI_U||R_U||TI_U||A_U^*)$.

Second, A has stolen U's device and extracted the stored information $\langle C_U, D_U, E_U, p, H(\cdot), x, d(\cdot), \delta, T_{X_S}(x) \rangle$.

Then, A can find out U's password PW_U through the following procedure.

(1) A guesses a candidate identity ID^* and a candidate password PW^* and computes $B^* = C_U \oplus H(ID^*||PW^*)$, $A^* = D_U \oplus H(ID^*||PW^*) \oplus B^*$, $L^* = H(DI_U||R_U||TI_U||A^*)$.
(2) A checks whether L^* and L_U are equal. If they are equal, A has got the correct identity and password pair; otherwise, A repeats the steps (1)–(2) until the correct password is obtained.

It is easy to see that the adversary can obtain the password through the above procedure. Therefore, Islam's scheme is vulnerable to off-line password guessing attack with the stolen smart card.

In practice, the user can be tracked by the identities present on several protocol layers, starting from the link layer up to application data [53]. Although Islam's scheme involves the use of dynamic identity on the application layer, it is not sufficient to achieve complete privacy protection. The adversary may still link two sessions of the user with the identities on the lower protocol layers, e.g., IP and MAC addresses. Therefore, the adversary may still link the request messages to a specific user.

Once again, we come to the conclusion that designing an authentication scheme based on the assumption that privacy protection is fulfilled in the scheme itself may pose potential security risks, as is indicated in [30].

4.4 Biometric template privacy leakage

The data stored in the smart card will leak biometric information since $C_U = H(ID_U||PW_U) \oplus B_U$ is stored. If the identity and password are also exposed, the adversary will be able to derive the biometric template. That is, the scheme fails to preserve biometric template privacy.

This also proves that it is not a truly three-factor authentication scheme, and the compromise of the password and smart card will cause the compromise of biometric.

5 Our improved scheme

To remedy these flaws presented in Sect. 4, we improve Islam's scheme in the following aspects. (1) We adopt the concept of fuzzy verifier [46] to fulfill local password verification. (2) We revise the computation of the value L_U to resist off-line password guessing attack with smart cards. (3) We employ the fuzzy extractor to preserve biometric template privacy.

As Islam's scheme, our scheme also consists of six phases: setup, registration, login, authentication, password and biometric update, and lost smart card revocation. Since the setup phase remains unchanged, it is omitted here.

5.1 Registration phase

U registers with S through a secure channel to be a legal user in this phase. Steps 1 and 2 remain unchanged, and Step 3 is presented as follows.

Step 3 After receiving SC_U, U selects the password PW_U and imprints the biometric B_U at the sensor. Then, the fuzzy extractor generates $(RS_U, P_U) = Gen(B_U)$, SC_U computes $C_U = H(ID_U||PW_U) \oplus RS_U$, $D_U = A_U \oplus C_U$, $E_U = H(C_U \bmod m)$, where m is a medium integer, $2^8 \leq m \leq 2^{16}$, which determines the capacity of the pool of the $\langle ID_U, \mathrm{PW}_U \rangle$ pair against off-line password guessing attack. Next, SC_U replaces A_U by $\langle D_U, E_U \rangle$, and it holds $\langle D_U, E_U, p, H(\cdot), x, P_U, T_{X_S}(x) \rangle$.

5.2 Login phase

In this phase, U initiates the authentication request, and the following steps are performed, as is shown in Fig. 2.

Step 1 U attaches his smart card SC_U to a card reader, and inputs ID_U, PW_U and imprints B'_U into SC_U.

Step 2 SC_U computes $RS^*_U = Gen(B'_U, P_U)$, $C^*_U = H(ID_U||PW_U) \oplus RS_U$, $A^*_U = D_U \oplus C^*_U$ and $E^*_U = H(C^*_U \bmod m)$. Then, if $E^*_U \neq E_U, SC_U$ aborts the session; otherwise, it proceeds to the next step.

Step 3 SC_U generates the current timestamp TI_U, a random number $r_U \in_R Z^*_P$, and computes $R_U = T_{r_U}(x)$, $X_U = T_{r_U}(T_{X_S}(x))$, $DI_U = ID_U \oplus H(X_U || TI_U)$, $L_U = H(DI_U||X_U||TI_U||A^*_U)$. Then, it sends the request message $\langle DI_U, R_U, TI_U, L_U \rangle$ to S.

5.3 Authentication phase

In this phase, U and S are mutually authenticated. As is shown in Fig. 2, the main body of this phase remains unchanged. The only change made is $L^*_U = H(DI_U||T_{X_s}(R_U)||TI_U||A^*_U)$ in Step 2, as compared with $L^*_U = H(DI_U||R_U||TI_U||A^*_U)$ in the original scheme.

5.4 Password and biometric update phase

In this phase, U executes the following steps to update his password and biometric template.

Step 1 U inserts SC_U into a card reader, imprints B'_U and inputs $\langle ID_U, PW_U \rangle$.

Step 2 Then, SC_U computes $RS^*_U = \mathrm{Gen}(B'_U, P_U)$, $C^*_U = H(ID_U||PW_U) \oplus RS_U$, $A^*_U = D_U \oplus C^*_U$ and $E^*_U = H(C^*_U \bmod m)$. Then, if $E^*_U \neq E_U, SC_U$ aborts the session; otherwise, it proceeds to the next step.

Step 3 U imprints B^n_U and inputs PW^n_U. Then, the fuzzy extractor generates $(RS^n_U, P^n_U) = Gen(B^n_U)$, SC_U, computes $C^n_U = H(ID_U||PW^n_U) \oplus RS^n_U$, $D^n_U = A^*_U \oplus C^n_U$, $E^n_U = H(C^n_U \bmod m)$, and updates $\langle D_U, E_U, p, H(\cdot), x, d(\cdot), \delta, T_{X_S}(x) \rangle$ to $\langle D^n_U, E_U, p, H(\cdot), x, P^n_U, T_{X_S}(x) \rangle$.

5.5 Lost smart card revocation phase

In this phase, U executes the following steps to revoke a lost smart card.

Step 1 U sends ID_U within the smart card revocation request to S.

Step 2 S checks the validity of U and ID_U. If both are valid, S gets a new smart card SC^n_U, extracts the identity SI^n_U, calculates $A^n_U = H(ID_U||SI^n_U||X_S)$, stores $\langle A^n_U, p, H(\cdot), x, d(\cdot), \delta, T_{X_S}(x) \rangle$ into SC^n_U and issues the card to U. S updates the tuple $\langle ID_U, SI_U, \mathrm{SB}_U, R_U \rangle$ to $\langle ID_U, SI^n_U, \mathrm{SB}_U, R_U \rangle$.

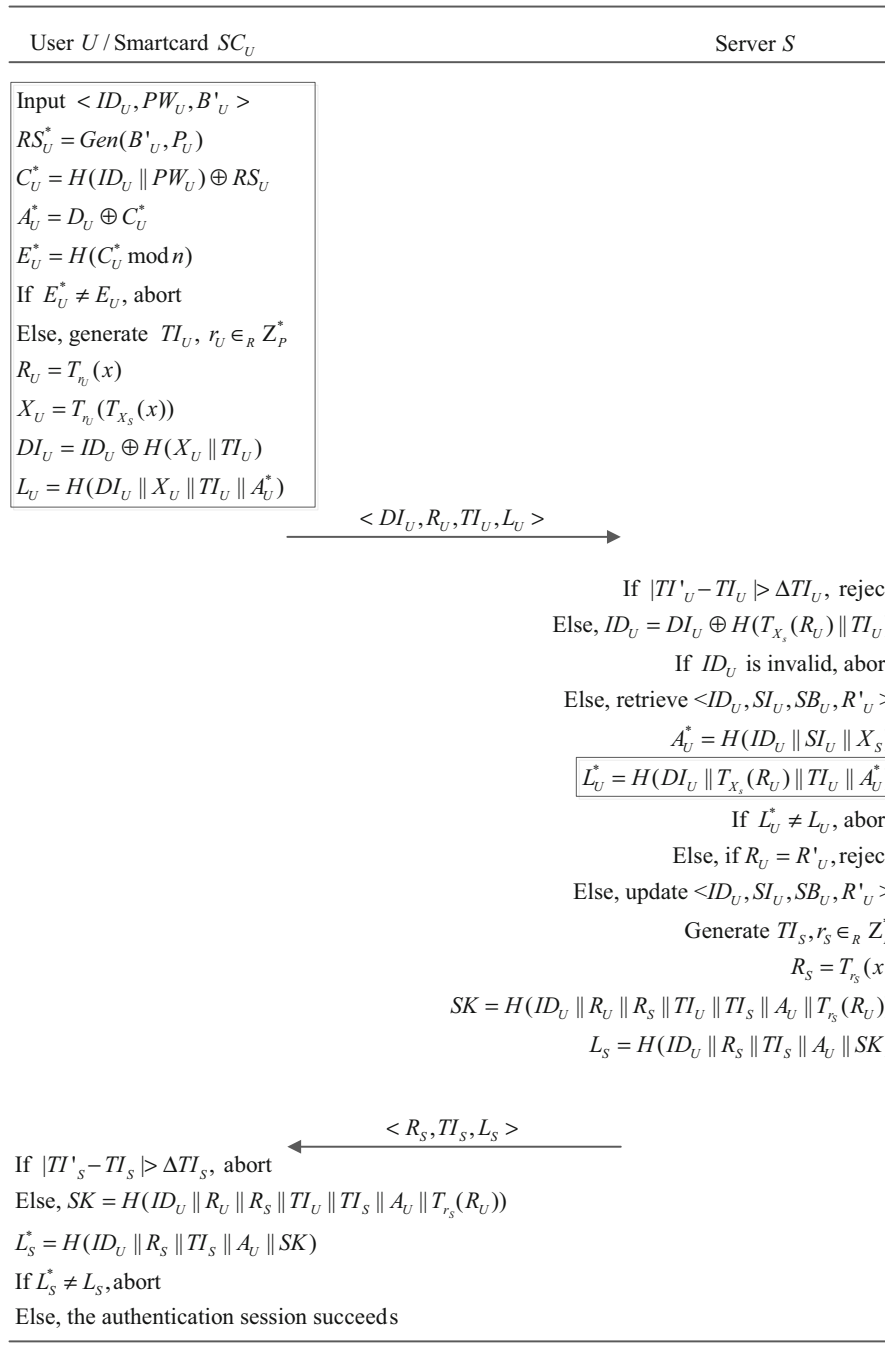


Fig. 2 Login and authentication phase of our improved scheme

Step 3 After receiving SC_U^n, U selects the new password PW_U^n and imprints the new biometric B_U^n. Then, the fuzzy extractor generates $(RS_U^n, P_U^n) = Gen(B_U^n)$, and SC_U^n computes $C_U^n = H(ID_U||PW_U^n) \oplus RS_U^n$, $D_U^n = A_U^n \oplus C_U^n$, $E_U^n = H(C_U^n \bmod m)$. Next, SC_U^n replaces A_U^n by $\langle D_U^n, E_U^n \rangle$, and it holds $\langle D_U^n, E_U^n, p, H(\cdot), x, d(\cdot), \delta, T_{X_S}(x) \rangle$.

6 Security analysis

In this section, we analyze the security of the proposed protocol. The BAN logic [44,54] is used to demonstrate that the proposed protocol fulfills mutual authentication. Then, we show that the proposed protocol withstands various attacks and achieves desired properties.

6.1 Authentication proof using BAN logic

The notations of the BAN logic are given as follows [44]:

- $P \models X$ The principal P believes a statement X, or P is entitled to believe X.
- $\#(X)$ The formula X is fresh.
- $P \Rightarrow X$ The principal P has jurisdiction over the statement X.
- $P \lhd X$ The principal P sees the statement X.
- $P \mid\sim X$ The principal P once said the statement X.
- (X, Y) The formula X or Y is one part of the formula (X, Y).
- $\langle X \rangle_Y$ The formula X combined with the formula Y.
- $\{X\}_K$ The formula X is encrypted under the key K.
- $(X)_K$ The formula X is hash with the key K.
- $P \overset{K}{\leftrightarrow} Q$ The principals P and Q use the shared key K to communicate. The key K will never be discovered by any principal except P and Q.
- SK The session key established in the current session.

Main logical postulates of the BAN logic are as follows [44]:

- The message-meaning rule: $\frac{P \models P \overset{K}{\leftrightarrow} Q, P \lhd \{X\}_K}{P \models Q \mid\sim X}$.
- The freshness-conjuncatenation rule: $\frac{P \models \#(X)}{P \models \#(X, Y)}$.
- The nonce-verification rule: $\frac{P \models \#(X), P \models Q \mid\sim X}{P \models Q \models X}$.
- The jurisdiction rule: $\frac{P \models Q \Rightarrow X, P \models Q \models X}{P \models X}$.

According to the analytic procedures of the BAN logic, the proposed protocol must satisfy the following goals:

Goal 1. $U \models (U \overset{SK}{\leftrightarrow} S)$;

Goal 2. $U \models S \models (U \overset{SK}{\leftrightarrow} S)$;

Goal 3. $S \models (U \overset{SK}{\leftrightarrow} S)$;

Goal 4. $S \models U \models (U \overset{SK}{\leftrightarrow} S)$;

First, we transform our improved scheme to the following idealized form:

Msg 1. $U \rightarrow S$: $(ID_U, R_U, TI_U)_{U \xleftarrow{H(ID_U \| SI_U \| X_S)} S}$

Msg 2. $S \rightarrow U$: $(R_S, TI_S, U \overset{SK}{\leftrightarrow} S)_{U \xleftarrow{H(ID_U \| SI_U \| X_S)} S}$

Second, we make the following assumptions about the initial state of the scheme to analyze the improved scheme:

A_1 : $U \models \#(R_U)$;

A_2 : $S \models \#(R_S)$;

A_3 : $U \models (U \xleftrightarrow{H(ID_U \| SI_U \| X_S)} S)$;

A_4 : $S \models (U \xleftrightarrow{H(ID_U \| SI_U \| X_S)} S)$;

A_5 : $U \models S| \Rightarrow (U \overset{SK}{\leftrightarrow} S)$;

A_6 : $S \models U| \Rightarrow (U \overset{SK}{\leftrightarrow} S)$;

Third, we analyze the idealized form of the improved scheme based on the BAN logic rules and assumptions. The main proofs are presented as follows:

According to *Msg* 1, we could get

S_1 : $S \lhd (ID_U, R_U, TI_U)_{U \xleftarrow{H(ID_U \| SI_U \| X_S)} S}$.

According to A_4, we apply the message-meaning rule to get

S_2 : $S \models U| \sim (ID_U, R_U, TI_U, U \overset{SK}{\leftrightarrow} S)$.

According to A_2, we apply the freshness-conjuncatenation rule to get

S_3 : $S \models U \models (ID_U, R_U, TI_U, U \overset{SK}{\leftrightarrow} S)$.

According to S_3, we apply the BAN logic rule to break conjunctions to produce

S_4 : $S \models U \equiv (U \overset{SK}{\leftrightarrow} S)$. (Goal 3)

According to A_6, we apply the jurisdiction rule to get

S_5 : $S \models (U \overset{SK}{\leftrightarrow} S)$. (Goal 4)

According to *Msg* 2, we could get

S_6 : $U \lhd (R_S, TI_S, U \overset{SK}{\leftrightarrow} S)_{U \xleftarrow{H(ID_U \| SI_U \| X_S)} S}$.

According to A_3, we apply the message-meaning rule to get

S_7 : $U \models S| \sim (R_S, TI_S, U \overset{SK}{\leftrightarrow} S)$.

According to A_1, we apply the freshness-conjuncatenation rule to get

S_8 : $U \models S \models (R_S, TI_S, USKS)$.

According to S_8, we apply the BAN logic rule to break conjunctions to produce

S_9 : $U \models S \models (U \overset{SK}{\leftrightarrow} S)$. (Goal 2)

According to A_5, we apply the jurisdiction rule to get

S_{10} : $U \models (U \overset{SK}{\leftrightarrow} S)$. (Goal 1)

According to (Goal 1), (Goal 2), (Goal 3), (Goal 4), we know that both of U and S believe that a session key SK are shared between U and S.

6.2 Security analysis against possible attacks

In this section, we show that our improved scheme also withstands various attacks, including undetectable online password guessing attack, off-line password guessing attack, privileged insider attack, stolen-verifier attack, replay attack, modification attack, man-in-the-middle attack, user impersonation attack and server impersonation attack.

6.2.1 Privileged insider attack

In the user registration phase of our protocol, the user only sends the identity to the server. That is, the privileged insider of the server cannot obtain any information related to PW_U. As a result, the scheme is secure against privileged insider attack.

6.2.2 Stolen-verifier attack

In stolen-verifier attack, a malicious user steals or modifies the verification data (e.g., plaintext passwords, hashed passwords) stored in the server. In our protocol, the server maintains a table consists of $\langle ID_U, SI_U, SB_U, R_U \rangle$, which contains no information related to the password. The only secret information that needs to be maintained by the server is the master key X_S. Hence, our scheme is secure against stolen-verifier attack.

6.2.3 Undetectable online password guessing attack

In our scheme, it is a necessity to input a correct password to generate the legal login (request) message. Suppose that an adversary guesses a candidate password to perform the login and authentication phase. According to the scheme, the server can detect the attack by confirming the validity of the value L_U in the request message $\langle DI_U, R_U, TI_U, L_U \rangle$. That is, online password guessing attack will be detected immediately. As a result, our scheme is immune from undetectable online password guessing attack.

6.2.4 Off-line password guessing attack with the stolen smart card

Suppose that the smart card and biometric template are compromised. A could get the stored data $\langle D_U, E_U, p, H(\cdot), x, P_U, T_{X_S}(x) \rangle$, the eavesdropped authentication messages, i.e., U's request $\langle DI_U, R_U, TI_U, L_U \rangle$ and S's response $\langle R_S, TI_S, L_S \rangle$.

The adversary can guess a candidate identity ID^* and password PW^* and compute $C_U^* = H(ID^*||PW^*) \oplus RS_U^*$, $E_U^* = H(C_U^* \mod m)$, $A_U^* = D_U \oplus C_U^*$.

On the one hand, the adversary can only verify the correctness of ID^* and PW^* probabilistically. The way for the adversary to learn PW_U is to find out the correct pair (ID^*, PW^*) such that $E_U^* = E_U$. In Sect. 5, we have shown that this strategy is infeasible as E_U is a "fuzzy verifier."

On the other hand, the attack presented in Sect. 4.2 is infeasible. The reason is presented as follows. Due to the hardness of CDH problem presented in Sect. 2.1, it is impossible for the adversary to compute $X_U = T_{r_U}(T_{X_S}(x))$. Thus, the adversary cannot compute $L^* = H(DI_U||X_U||TI_U||A^*)$, which is essential to verify the correctness of the guessed password. Therefore, off-line password guessing attack is impossible in our scheme.

6.2.5 Replay attack

An adversary A could replay the eavesdropped messages, such as U's request $\langle DI_U, R_U, TI_U, L_U \rangle$ or S's response $\langle R_S, TI_S, L_S \rangle$. However, the valid period of each message is limited by the timestamp TI_U and TI_S, respectively, so a replay attack can be easily detected by checking the freshness of the timestamp. In addition, the adversary cannot bypass the timestamp checking, because these messages are protected by hash function. Therefore, replay attack cannot succeed in our scheme.

6.2.6 Modification attack

The adversary A could intercept the message flows and transmit modified messages instead of the original ones. In our scheme, the request message is generated by the hash function using $X_U = T_{r_U}(T_{X_S}(x))$ and A_U, and the response message is generated by the hash function using A_U and $T_{r_S}(R_U)$. Any modification will be detected in the message verification steps, because A cannot generate correct L_U or L_S without knowing A_U. Therefore, the proposed protocol is secure against the modification attack.

6.2.7 User impersonation attack

If an adversary A wants to impersonate a valid user U to the server S. A has to compute L_U to prove its legitimacy. However, A is unable to compute the correct value L_U because he does not know the secret key A_U. To get A_U, the adversary has to provide all the three factors. Even any two of the three factors are compromised, A_U still cannot be computed. That is, the adversary has no way to compute a valid L_U. As a result, our improved scheme is secure against user impersonation attack.

6.2.8 Server impersonation attack

If an adversary A wants to impersonate S and to spoof user U, A needs to generate a valid response $\langle R_S, TI_S, L_S \rangle$. However, A has no knowledge of the server's secret key X_S, so A cannot compute A_U. As a result, A cannot correctly compute L_S to generate a valid response. Therefore, our improved scheme is secure against server impersonation attack.

6.2.9 Man-in-the-middle attack

An adversary A could intercept the messages transmitted between the user and server and replace them with his own messages. In our scheme, A cannot compute the value L_U which is derived from the value A_U, without the knowledge of either D_U, the identity and password pair, the legitimate biometric or the server secret key X_S, so it is impossible to generate the correct value L_U. Moreover, it is also impossible to compute the correct value L_S for the same reason. A cannot pass the verification of the server or the user. Hence, our scheme can defend man-in-the-middle attack.

6.2.10 Denial of service attack

In password and biometric template update phase, the smart card checks the validity of user input identity ID^* and password PW^* before the update process. Since the smart card computes $C_U^* = H(ID^*||\mathrm{PW}^*) \oplus RS_U^*$, $E_U^* = H(C_U^* \mod m)$ and compares E_U^* with the stored value of E_U to verify the legality of the user before the smart card accepts the password and biometric update request. Hence, denial of service attack is thwarted.

6.3 Desired security properties

In addition, the improved scheme achieves mutual authentication, secure channel establishment, perfect forward secrecy, user anonymity and untraceability, and biometric template privacy protection.

6.3.1 Mutual authentication

Mutual authentication means that the server and user can verify the identity of each other to establish mutual confidence before releasing the private information. In our scheme, only the legitimate user with the correct password, biometrics and the smart card can pass the verification of the server, and only the server with correct secret key can pass the verification of the user. As a result, our scheme provides a mechanism that allows the user and the server to authenticate each other. That is, the scheme achieves mutual authentication between a legal user and the server.

6.3.2 Secure channel

After a user logs in the server successfully, another critical security issue is to ensure data confidentiality and integrity during data communication. In our scheme, when mutual authentication has completed, both U and S share the session key $\mathrm{SK} = H(ID_U||R_U||R_S||TI_U||TI_S||A_U||T_{r_S}(R_U))$. In addition, the session key SK is generated independently and is different for each login session. Hence, even if some session keys are revealed, the previous and future session keys are still secure. All of the data transmission will be protected by the session key, and no adversary can eavesdrop, modify, or delete the data in transition. Therefore, a secure channel is established in our scheme.

6.3.3 Perfect forward secrecy

Perfect forward secrecy means that previously established session key remains secure even when the long-term keys of the server and the user are disclosed. In our scheme, the long-term private keys of the user are the value D_U stored in the smart card and the password PW_U, and that of the server is the secret key X_S. Even if the values D_U, PW_U, and X_S are compromised, the session key $SK =$

Table 1 Comparison of security features

Functionality\scheme	Lee and Hsu's [39]	Islam's [40]	Ours
Privileged insider attack	Yes	Yes	Yes
Stolen-verifier attack	Yes	Yes	Yes
Online password guessing attack	Yes	Yes	Yes
Off-line password guessing attack	No	No	Yes
Replay attack	Yes	Yes	Yes
Modification attack	Yes	Yes	Yes
User impersonation attack	No	No	Yes
Server impersonation attack	Yes	Yes	Yes
Man-in-the-middle attack	Yes	Yes	Yes
Denial of service attack	No	Yes	Yes
Mutual authentication	Yes	No	Yes
Secure channel	Yes	Yes	Yes
Perfect forward secrecy	Yes	Yes	Yes
User anonymity	Yes	Yes	Yes
User untraceability	Yes	Yes	Yes
Biometric template privacy	No	No	Yes

$H(ID_U||R_U||R_S||TI_U||TI_S||A_U||T_{r_S}(R_U))$ of the previous session remains secure, since the adversary is computationally infeasible to calculate the session key with $R_U = T_{r_U}(x)$ and $R_S = T_{r_S}(x)$.

6.3.4 User anonymity

User anonymity ensures that any third party cannot know the identity of U, except the U himself and the sever S. In our scheme, the user identity ID_U is concealed in DI_U. In order to obtain ID_U, the adversary has to compute $X_U = T_{r_U}(T_{X_S}(x))$. Without knowing X_S, it is infeasible for the adversary to compute X_U, due to the hardness of CDH problem presented in Sect. 2.1. Therefore, it is impossible for the adversary to get the user identity from the protocol transcripts. In other words, our scheme achieves user anonymity.

6.3.5 User untraceability

User untraceability means that the adversary cannot identify any two past protocol runs which have the same user involved. In our scheme, each field presented in the request message $\langle DI_U, R_U, TI_U, L_U\rangle$ and S's response $\langle R_S, \mathrm{TI}_S, L_S\rangle$ is dynamic for each login session. R_U is randomly generated for each session, in turn, DI_U is different for each session. Besides, the timestamp TI_U is attached to each session. So the value of L_U is dynamic for each session. Therefore, the adversary is unable to tell whether two protocol runs have the same user involved, and our scheme achieves user untraceability.

6.3.6 Biometric template privacy

The improved scheme preserves biometric template privacy due to the following two reasons. First of all, the server has no information about the user's biometric template. The user provides no biometric templates to the server. Secondly, the data stored in the smart card will not leak biometric information since the probability of successful recovering the biometric template with RS_U and P_U is negligible [41].

6.4 Comparison of security features

We compare our proposed authentication scheme with existing authentication schemes [39,40] in terms of security. The results of comparison are shown in Table 1. From Table 1, it is obvious that our scheme is the only one which is capable of resisting all known attacks and fulfills the desirable security properties.

Table 2 Comparison of computation cost

Schemes	Lee and Hsu's [39]	Islam's [40]	Our
P_1	$4T_H + T_C$	$2T_H + T_C$	$3T_H$
P_2	$5T_H + 2T_C$	$4T_H + 3T_C$	$4T_H + 2T_C$
P_3	$7T_H + 4T_C$	$7T_H + 4T_C$	$7T_H + 4T_C$
P_4	$5T_H$	$3T_H + T_C$	$4T_H$
P_5	$4T_H + T_C$	$2T_H + T_C$	$3T_H$
Overall computation cost	$25T_H + 8T_C$	$18T_H + 10T_C$	$21T_H + 6T_C$
Communication cost	1584 bits	1312 bits	1312 bits
Communication rounds	3	2	2

7 Efficiency discussions

In this section, we discuss the efficiency of our proposed scheme. We define the involved notations as follows.

P_1 the computation cost in registration phase;
P_2 the computation cost in login phase;
P_3 the computation cost in authentication phase;
P_4 the computation cost in password and biometric update phase;
P_5 the computation cost in smart card revocation phase;
T_H the time for performing the hash operation;
T_C the time for performing the extended chaotic map operation.

According to [20], the execution time for the cryptographic operation is as follows: $T_H \approx 0.20$ ms and $T_C \approx 32.40$ ms. The hardware platform is a PIV 3.2 GHz processor with 3.0 GB RAM. We compare the efficiency of our scheme with that of Islam's scheme and Lee and Hsu's scheme in Table 2. We also graphically represent the computation cost comparison in Fig. 3.

We can see that the computation cost of our scheme is lower than that of Islam's scheme in the registration, login phase, password and biometric update and smart card revocation phase. The computation cost of our scheme is the same as that of Islam's scheme in the authentication phase. Thus, our scheme is more efficient than Islam's scheme in terms of overall computation cost. It is obvious that the cost of our scheme is also lower than that of Lee and Hsu's scheme. Additionally, as is demonstrated in Sect. 4, Islam's scheme fails to fulfill three-factor security. From Tables 1 and 2, we conclude that the proposed scheme is robust and efficient in terms of security strength and computation.

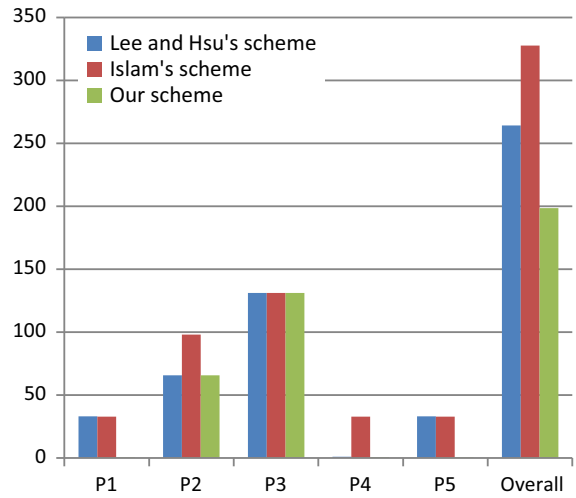


Fig. 3 Execution time of different protocols

8 Conclusion

In this paper, we have first reviewed Islam's scheme and then shown that the process of password verification in the login phase is invalid, that is, no matter the inputted identity and password are correct or not, the user can pass the password verification. In addition, we have demonstrated that it is vulnerable to user impersonation attack and off-line password guessing attack, if the smart card is lost or stolen. Furthermore, it fails to preserve biometric template privacy in the case that the password and the smart card are compromised. Then, we have proposed a robust three-factor authentication scheme to remedy these drawbacks in Islam's scheme.

We have proved that the scheme fulfills mutual authentication in the BAN logic. Through the informal security analysis, we have demonstrated that the proposed scheme is secure and it can withstand various attacks and fulfill a variety of desired security properties. What is more, our scheme is more efficient than the previous schemes and provides more features as compared with Islam's scheme.

Acknowledgments This work is supported by National Natural Science Foundation of China (Program Nos. 61202389, U1405255, 61309016, 61372075, 61201220, U1135002), National High Technology Research and Development Program (863 Program) (Program No. 2015AA011704), Fundamental Research Funds for the Central Universities (Program No. JB140302). The authors also extend their appreciation to the Deanship of Scientific Research at King Saud University, Riyadh, Saudi Arabia, for funding this work through the research group Project No. RGP-VPP-318. The authors would like to thank the anonymous reviewers and the editor for their constructive comments that have helped us to improve this paper.

References

1. Xia, Z., Wang, X., Sun, X., Wang, Q.: A secure and dynamic multi-keyword ranked search scheme over encrypted cloud data. IEEE Trans. Parallel Distrib. Syst. (2015). doi:10.1109/TPDS.2015.2401003
2. Fu, Z., Sun, X., Liu, Q., Zhou, L., Shu, J.: Achieving efficient cloud search services: multi-keyword ranked search over encrypted cloud data supporting parallel computing. IEICE Trans. Commun. **E98–B**(1), 190–200 (2015)
3. Ren, Y., Shen, J., Wang, J., Han, J., Lee, S.: Mutual verifiable provable data auditing in public cloud storage. J. Internet Technol. **16**(2), 317–323 (2015)
4. Guo, P., Wang, J., Li, B., Lee, S.: A variable threshold-value authentication architecture for wireless mesh networks. J. Internet Technol. **15**(6), 929–936 (2014)
5. Zhao, D., Peng, H., Li, L., Yang, Y.: A secure and effective anonymous authentication scheme for roaming service in global mobility networks. Wirel. Pers. Commun. **78**(1), 247–269 (2014)
6. Wang, D., He, D., Wang, P., Chu, C.-H.: Anonymous two-factor authentication in distributed systems: certain goals are beyond attainment. IEEE Trans. Depend. Secure Comput. **12**(4), 428–442 (2015). doi:10.1109/TDSC.2014.2355850
7. Wang, D., Wang, N., Wang, P., Qing, S.: Preserving privacy for free: efficient and provably secure two-factor authentication scheme with user anonymity. Inf. Sci. **321**, 162–178 (2015). doi:10.1016/j.ins.2015.03.070
8. O'Gorman, L.: Comparing passwords, tokens, and biometrics for user authentication. Proc. IEEE **91**(12), 2021–2040 (2003)
9. Yu, J., Wang, G., Mu, Y., Gao, W.: An efficient and improved generic framework for three-factor authentication with provably secure instantiation. IEEE Trans. Inf. Forensics Secur. **9**(12), 2302–2313 (2014). doi:10.1109/TIFS.2014.2362979
10. Huang, X., Xiang, Y., Chonka, A., Zhou, J., Deng, R.H.: A generic framework for three-factor authentication: preserving security and privacy in distributed systems. IEEE Trans. Parallel Distrib. Syst. **22**(8), 1390–1397 (2011)
11. Lin, C.H., Lai, Y.Y.C.H.: A flexible biometrics remote user authentication scheme. Comput. Stand. Interfaces **27**, 19–23 (2004)
12. Khan, M.K., Zhang, J.S.: Improving the security of 'a flexible biometrics remote user authentication scheme'. Comput. Stand. Interfaces **29**, 82–85 (2007)
13. Li, C.-T., Hwang, M.-S.: An efficient biometrics-based remote user authentication scheme using smart cards. J. Netw. Comput. Appl. **33**, 1–5 (2010)
14. Li, X., Niu, J.W., Ma, J., Wang, W.D., Liu, C.L.: Cryptanalysis and improvement of a biometric-based remote authentication scheme using smart cards. J. Netw. Comput. Appl. **34**, 73–79 (2011)
15. Das, A.K.: Analysis and improvement on an efficient biometric-based remote user authentication scheme using smart cards. IET Inf. Secur. **5**(3), 145–151 (2012)
16. Fan, C.I., Lin, Y.H.: Provably secure remote truly three factor authentication scheme with privacy protection on biometrics. IEEE Trans. Inf. Forensics Secur. **4**, 933–945 (2009)
17. Li, X., Niu, J., Wang, Z., Chen, C.: Applying biometrics to design three-factor remote user authentication scheme with key agreement. Secur. Commun. Netw. **7**(10), 1488–1497 (2013)
18. Li, L., Peng, H., Kurths, J., Yang, Y., Schellnhuber, H.J.: Chaos-order transition in foraging behavior of ants. PNAS **111**(23), 8392–8397 (2014)
19. Niu, Y.J., Wang, X.Y.: An anonymous key agreement protocol based on chaotic maps. Commun. Nonlinear Sci. Numer. Simul. **16**, 1986–1992 (2011)
20. Xue, K., Hong, P.: Security improvement on an anonymous key agreement protocol based on chaotic maps. Commun. Nonlinear Sci. Numer. Simul. **17**, 2969–2977 (2012)
21. Lee, T.-F.: Enhancing the security of password authenticated key agreement protocols based on chaotic maps. Inf. Sci. **290**, 63–71 (2015)
22. Gong, P., Li, P., Shi, W.: A secure chaotic maps-based key agreement protocol without using smart cards. Nonlinear Dyn. **70**, 2401–2406 (2012)
23. Xie, Q., Tu, X.: Chaotic maps-based three-party password authenticated key agreement scheme. Nonlinear Dyn. **74**, 1021–1027 (2013)
24. Zhao, F., Gong, P., Li, S., Li, M., Li, P.: Cryptanalysis and improvement of a three-party key agreement protocol using enhanced Chebyshev polynomials. Nonlinear Dyn. **74**, 419–427 (2013)
25. Lee, C.-C., Li, C.-T., Hsu, C.-W.: A three-party password based authenticated key exchange protocol with user anonymity using extended chaotic maps. Nonlinear Dyn. **73**, 125–132 (2013)
26. Farash, M.S., Attari, M.A.: An efficient and provably secure three-party password-based authenticated key exchange protocol based on Chebyshev chaotic maps. Nonlinear Dyn. **77**(1), 399–411 (2014). doi:10.1007/s11071-014-1304-6
27. Lai, H., Orgun, M.A., Xiao, J., Pieprzyk, J., Xue, L., Yang, Y.: Provably secure three-party key agreement protocol using Chebyshev chaotic maps in the standard model. Nonlinear Dyn. **77**(4), 1427–1439 (2014)

28. Guo, C., Chang, C.-C.: Chaotic maps-based password authenticated key agreement using smart cards. Commun. Nonlinear Sci. Numer. Simul. **18**(6), 1433–1440 (2013)
29. Hao, X., Wang, J., Yang, Q., Yan, X., Li, P.: A chaotic map based authentication scheme for telecare medicine information systems. J. Med. Syst. **37**(2), 1–7 (2013)
30. Jiang, Q., Ma, J., Lu, X., Tian, Y.: Robust chaotic map-based authentication and key agreement scheme with strong anonymity for telecare medicine information systems. J. Med. Syst. **38**(2), 1–8 (2014)
31. Yau, W.C., Phan, R.C.W.: Security analysis of a chaotic map based authentication scheme for telecare medicine information systems. J. Med. Syst. **37**(6), 1–9 (2013)
32. Yau, W.C., Phan, R.C.W.: Cryptanalysis and improvement of a three-party key agreement protocol using enhanced Chebyshev polynomials. Nonlinear Dyn. **79**(2), 809–821 (2014). doi:10.1007/s11071-014-1704-7
33. Tan, Z.: A chaotic maps-based authenticated key agreement protocol with strong anonymity. Nonlinear Dyn. **72**(1–2), 311–320 (2013)
34. Li, C.T., Lee, C.C., Weng, C.Y.: An extended chaotic maps based user authentication and privacy preserving scheme against DoS attacks in pervasive and ubiquitous computing environments. Nonlinear Dyn. **74**(4), 1133–1143 (2013)
35. Lee, C.C., Lou, D.C., Li, C.T.: An extended chaotic maps-based protocol with key agreement for multiserver environments. Nonlinear Dyn. **76**(1), 853–866 (2013). doi:10.1007/s11071-013-1174-3
36. Khan, M.K., Zhang, J., Wang, X.: Chaotic hash-based fingerprint biometric remote user authentication scheme on mobile devices. Chaos, Solitons Fract. **35**(3), 519–524 (2008)
37. Lee, C.C., Chen, C.C., Wu, C.Y., Huang, S.-Y.: An extended chaotic maps-based key agreement protocol with user anonymity. Nonlinear Dyn. **69**(1–2), 79–87 (2012)
38. He, D., Chen, Y., Chen, J.: Cryptanalysis and improvement of an extended chaotic maps-based key agreement protocol. Nonlinear Dyn. **69**(3), 1149–1157 (2012)
39. Lee, C.C., Hsu, C.W.: A secure biometric-based remote user authentication with key agreement scheme using extended chaotic maps. Nonlinear Dyn. **71**(1–2), 201–211 (2013)
40. Islam, S.K.H.: Provably secure dynamic identity-based three-factor password authentication scheme using extended chaotic maps. Nonlinear Dyn. **78**(3), 2261–2276 (2014). doi:10.1007/s11071-014-1584-x
41. Dodis Y., Reyzin L., Smith A.: Fuzzy extractors: How to generate strong keys from biometrics and other noisy data. In: Proceedings of EUROCRYPT, pp. 523–540(2004)
42. Juels A., Sudan M.: A fuzzy vault scheme. In: Proceedings of International Symposium on Information Theory (ISIT), p. 408 (2002)
43. Nagar, A., Nandakumar, K., Jain, A.K.: Securing fingerprint template: fuzzy vault with minutiae descriptors. In: Proceedings of 19th International Conference on Pattern Recognition, pp. 1–4 (2008)
44. He, D., Kumar, N., Lee, J.-H.: Enhanced three-factor security protocol for USB consumer storage devices. IEEE Trans. Consum. Electr. **60**(1), 30–37 (2014)
45. He, D., Wang, D.: Robust biometrics-based authentication scheme for multi-server environment. IEEE Syst. J. **9**(3), 816–823 (2015). doi:10.1109/JSYST.2014.2301517
46. Wang, D., Wang, P., Ma, C., Chen, Z.: iPass: privacy preserving two-factor authentication scheme against smart card loss problem. Cryptology ePrint Archive **439**, 1–35 (2012). http://eprint.iacr.org/2012/439.pdf
47. Bergamo, P., Arco, P., Santis, A., Kocarev, L.: Security of public key cryptosystems based on Chebyshev polynomials. IEEE. Trans. Circ. Syst. **52**, 1382–1393 (2005)
48. Zhang, L.: Cryptanalysis of the public key encryption based on multiple chaotic systems. Chaos Solitons Fract. **37**(3), 669–674 (2008)
49. Kocher, P., Jaffe, J., Jun, B.: Differential power analysis. In: Proceedings of Advances in Cryptology (Crypto'99), LNCS, pp. 388–397 (1999)
50. Messerges, T.S., Dabbish, E.A., Sloan, R.H.: Examining smart-card security under the threat of power analysis attacks. IEEE Trans. Comput. **51**(5), 541–552 (2002)
51. Jiang, Q., Ma, J., Li, G., Yang, L.: An efficient ticket based authentication protocol with unlinkability for wireless access networks. Wirel. Pers. Commun. **77**(2), 1489–1506 (2014)
52. Jiang, Q., Ma, J., Lu, X., Tian, Y.: An efficient two-factor user authentication scheme with unlinkability for wireless sensor networks. Peer-to-Peer Netw. Appl. **8**(6), 1070–1081 (2015). doi:10.1007/s12083-014-0285-z
53. Arkko, J., Nikander, P., Näslund, M.: Enhancing Privacy with Shared Pseudo Random Sequences, Security Protocols. Springer, Berlin (2007)
54. Burrows, M., Abadi, M., Needham, R.: A logic of authentication. ACM Trans. Comput. Syst. **8**(1), 18–36 (1990)